Strecht Simulados

Resumo de bolso ISC2 CC

Domínios cobrados, as dicas de prova mais importantes e 10 questões comentadas para treinar.

600	6	70%
questões no curso	provas completas	nota de corte

Como é a prova ISC2 CC



Material independente de preparação, sem afiliação ou endosso de ISC2. As questões são inéditas e não reproduzem a prova real.

Pronto para o exame ISC2 CC?

Treine com as 600 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →

Dicas de prova por domínio

Operações de segurança e resposta a incidentes

- Muitos alertas: priorizar por gravidade e ativo.
- Pagar por falhas encontradas: bug bounty.
- Destruir confidencial impresso: regra da classificação.
- Hash quebrado: MD5.
- Sistema sem atualização: falhas sem correção.
- Chaves críticas: HSM.
- Logs protegidos: evitar que apaguem rastros.
- Desvio do comportamento normal: UEBA.

Conceitos de segurança de redes e nuvem

- Wi-Fi público: usar VPN.
- Muitas portas testadas: varredura de portas.
- Alugar VMs e instalar o SO: IaaS.
- Substituir Telnet: SSH.
- DMZ invadida: bloquear conexões da DMZ para dentro.
- Portal de boas-vindas não cifra o tráfego.
- Wi-Fi com credencial individual: Enterprise/802.1X.
- Fim do contrato SaaS: exportar e exigir exclusão.

Conceitos de gestão de identidade e acesso (IAM)

- Uma entrada para vários sistemas: SSO.
- Bloqueio abusado: bloqueio progressivo e detecção.
- Controlar contas privilegiadas: inventariar primeiro.
- Ver dados de outro usuário do mesmo nível: escalonamento horizontal.
- MFA conforme o risco: autenticação adaptativa.
- Crachá + PIN na porta: acesso físico com 2 fatores.
- Need to know: informação. Privilégio mínimo: permissões.
- Habilitado, mas sem necessidade: need to know.

Princípios de segurança

- Compartilhar com terceiro: base legal, finalidade e contrato.

- Chave perdida: sigilo prejudicou a disponibilidade.
- Priorizar ativos: valor e criticidade.
- Arquivo sensível por e-mail: cifrar.
- Publicar sem identificar ninguém: anonimização.
- Fazer e verificar: devido cuidado e devida diligência.
- Dado enviado a quem não devia: confidencialidade.
- Dado alterado sem autorização: integridade.

Governança de segurança

- Troca de conta bancária por e-mail: confirmar por outro canal.
- Proteção das contas críticas: % de admins com MFA.
- Relatar sem medo: resposta mais rápida.
- Checar controles todo dia: monitoramento contínuo.
- Lista de riscos com dono e resposta: registro de riscos.
- Olhar a tela: shoulder surfing.
- Incêndio: pessoas primeiro.
- Perda máxima de dados: RPO.

10 questões para treinar

Responda antes de olhar o gabarito, no fim do material.

Questão 1 · Operações de segurança e resposta a incidentes

Qual é o objetivo principal de um exercício de equipe vermelha (red team)?

A. Simular atacantes reais para testar detecção e resposta
B. Atender os chamados de suporte dos usuários
C. Configurar os firewalls e os servidores da empresa toda semana
D. Escrever as políticas de segurança da organização

Questão 2 · Princípios de segurança

Qual sequência representa o ciclo de gestão de riscos?

A. Planejar, codificar, testar e publicar software
B. Comprar, instalar, esquecer e substituir controles
C. Identificar, avaliar, tratar e monitorar os riscos
D. Detectar, conter, erradicar e recuperar sistemas

Questão 3 · Princípios de segurança

Um funcionário apagou sem querer uma tabela importante do banco de dados. Como classificar essa ameaça?

A. Ameaça humana acidental
B. Ameaça persistente avançada
C. Ameaça natural ambiental
D. Ameaça de hacktivista

Questão 4 · Operações de segurança e resposta a incidentes

Uma ferramenta testa a aplicação web em execução, enviando entradas maliciosas como faria um atacante. Que tipo de teste é esse?

A. Análise estática (SAST)
B. Teste de intrusão físico
C. Análise dinâmica (DAST)
D. Revisão de política escrita

Questão 5 · Princípios de segurança

A empresa migrou sistemas para a nuvem e passou a trabalhar com fornecedores novos. O que deve acontecer com a avaliação de riscos?

A. Ficar como está até a próxima década
B. Ser descartada, pois a nuvem é segura
C. Ser entregue ao provedor de nuvem
D. Ser revisada, pois o ambiente mudou

Questão 6 · Princípios de segurança

Um sistema de prevenção de intrusão (IPS) descarta automaticamente pacotes de ataque conhecidos. Como classificar esse controle?

A. Físico e compensatório
B. Administrativo e diretivo
C. Físico e detectivo
D. Técnico e preventivo

Questão 7 · Princípios de segurança

Uma empresa quer guias detalhados de configuração segura para Windows, Linux e bancos de dados, criados por consenso da comunidade. Qual referência usar?

A. O padrão IEEE 802.11
B. O protocolo NTP
C. O modelo OSI da ISO
D. Os CIS Benchmarks

Questão 8 · Governança de segurança

A empresa escolhe um funcionário de cada área para divulgar boas práticas e ser o ponto de contato com a equipe de segurança. Que iniciativa é essa?

A. Teste de intrusão de caixa-preta
B. Rede de embaixadores de segurança
C. Análise de impacto nos negócios
D. Plano de recuperação de desastres

Questão 9 · Conceitos de segurança de redes e nuvem

Em um data center, cada carga de trabalho só pode falar com as outras de que realmente precisa, com políticas individuais. Que técnica é essa?

A. Tradução de endereços
B. Roteamento estático
C. Rede plana única
D. Microssegmentação

Questão 10 · Princípios de segurança

Um servidor vale R$ 50 mil e um incêndio destruiria 40% dele. Esse incêndio é esperado uma vez a cada 10 anos. Qual é a perda anual esperada (ALE)?

A. R$ 2.000 por ano
B. R$ 5.000 por ano
C. R$ 50.000 por ano
D. R$ 20.000 por ano

Gabarito comentado

1. A) Simular atacantes reais para testar detecção e resposta
Red team: simular atacantes reais.

2. C) Identificar, avaliar, tratar e monitorar os riscos
Ciclo de riscos: identificar, avaliar, tratar, monitorar.

3. A) Ameaça humana acidental
Apagou sem querer: ameaça humana acidental.

4. C) Análise dinâmica (DAST)
Aplicação rodando: DAST.

5. D) Ser revisada, pois o ambiente mudou
Ambiente mudou: revisar os riscos.

6. D) Técnico e preventivo
IPS: técnico e preventivo.

7. D) Os CIS Benchmarks
Guias de configuração segura: CIS Benchmarks.

8. B) Rede de embaixadores de segurança
Pessoas de referência nas áreas: embaixadores.

9. D) Microssegmentação
Política por carga de trabalho: microssegmentação.

10. A) R$ 2.000 por ano
ALE = SLE x ARO.

Pronto para o exame ISC2 CC?

Treine com as 600 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →